Capstone Project Assessment

Project 1 – Threat Model the AI Identity System

1. Threat Modelling – Identity types in the SecureNova AI Platform

1.1 Human user (customer)

The actual end-user or customer interacting with the application. This is a highly secure, standard flow for public and native applications to securely authenticate users without exposing credentials.

Authentication Mechanism	**Auth0 Universal Login** utilizing **OIDC Auth Code** + **PKCE**, alongside **TOTP MFA** (Time-based One-Time Password Multi-Factor Authentication).
Privilege Level	**read:ai-data** (own data only). The user can only view or read AI-generated data or responses that belong strictly to their own account context.

1.2 Human admin / support lead

Internal staff members who manage the system or provide customer support.

Authentication Mechanism	The same as the user (**Auth0** + **MFA**), but strictly enforced through an enterprise connection (**SSO**).
Privilege Level	**read:ai-data**, **write:admin**. They have elevated privileges allowing them to read general AI data and execute administrative write/configuration actions.

1.3 AI agent (LLM agent)

The central core AI or Large Language Model orchestrator executing tasks.

Authentication Mechanism	Acts on behalf of user via a **user's access token** (OBO - On-Behalf-Of flow) combined with an **agent_id claim** using Ed25519-signed inter-agent messages. This ensures that the agent's actions are cryptographically signed and directly tied to the authorizing user's session.

Privilege Level	**Inherits user scope**, never more. The AI agent is strictly **sandboxed**; it cannot perform any action or access any data that the initiating human user does not already have permission to access.

1.4 OAuth M2M client (agent backend)

The backend service infrastructure supporting the AI agent, communicating machine-to-machine (M2M).

Authentication Mechanism	**Client Credentials** utilizing a client_secret or private_key_jwt with a short 60-300s TTL (Time-To-Live). This is standard for secure server-to-server communication where tokens expire rapidly to reduce exposure of windows.
Privilege Level	**read:ai-data**. The backend service has programmatic read access to the broader pool of AI system data to serve its functions.

1.5 LLM API key (model provider)

The credential used to authenticate requests sent to the upstream foundational model provider (e.g., OpenAI, Anthropic).

Authentication Mechanism	Static **bearer key** securely injected and retrieved via a secrets manager.
Privilege Level	Inference only, billing exposure. This key is strictly restricted to **running model inference** (generating text/data) but carries a risk profile related to **financial/billing consumption** if abused

1.6 RAG pipeline service identity

The automated background service responsible for Retrieval-Augmented Generation (RAG) processes.

Authentication Mechanism	**M2M token** providing read-only access to the vector store database.
Privilege Level	**read:kb**. It holds restricted permission to query and read data from the system's Knowledge Base (kb) to contextualize LLM prompts.

1.7 MCP server identity

The Model Context Protocol (MCP) server identity, which manages tools or integrations the AI can invoke.

Authentication Mechanism	**M2M token per tool** paired with a per-tool scope. Every tool integration has its own isolated, highly specific token.
Privilege Level	Tool-specific (**write:admin**, **read:pii-export**). Depending on the specific tool's role, it can carry highly sensitive privileges like administrative writes or exporting Personally Identifiable Information (PII).

2. STRIDE Matrix – With Data Flow Diagram

2.1 STRIDE Matrix

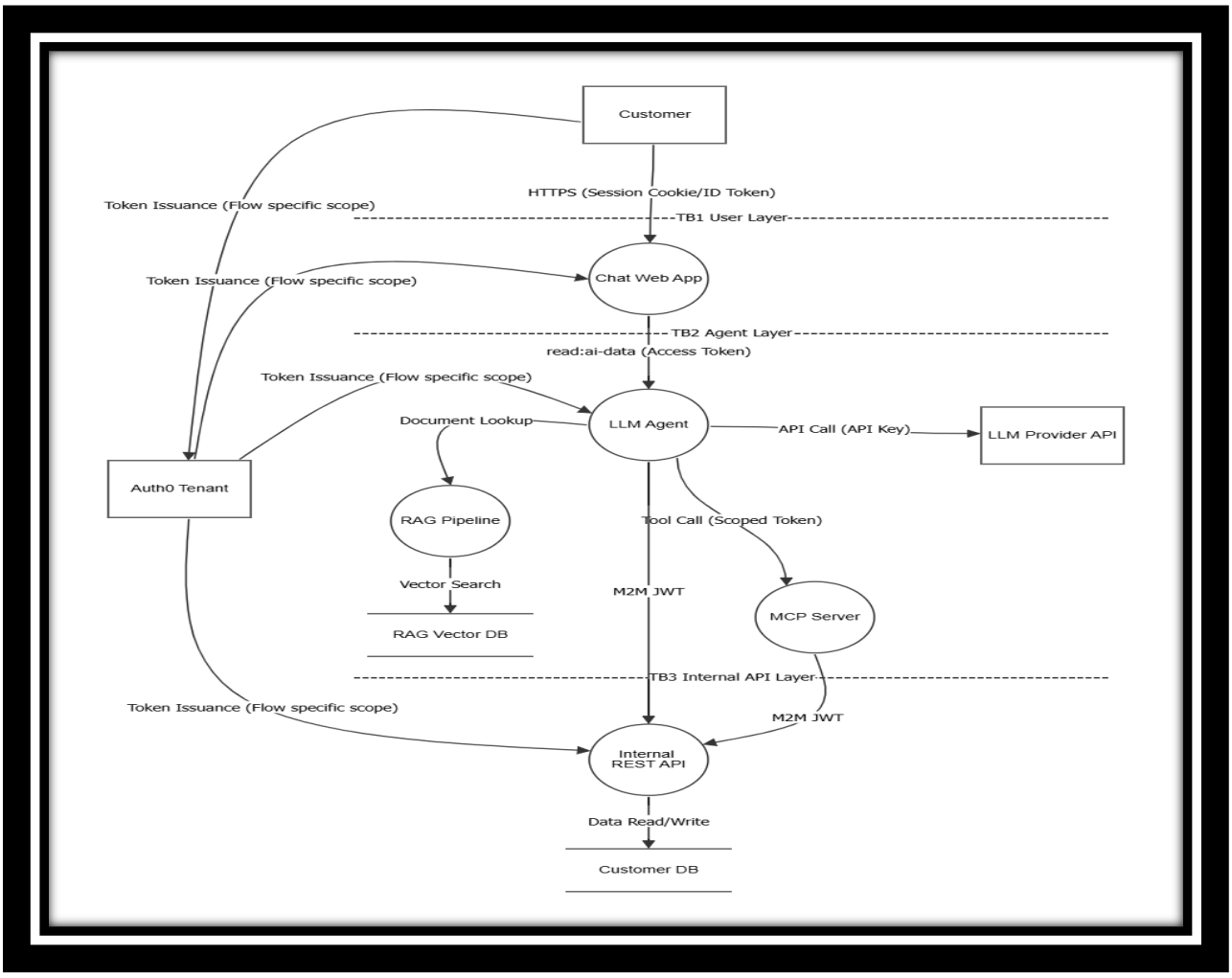
Applying all six STRIDE categories to every identity flow) in the system.

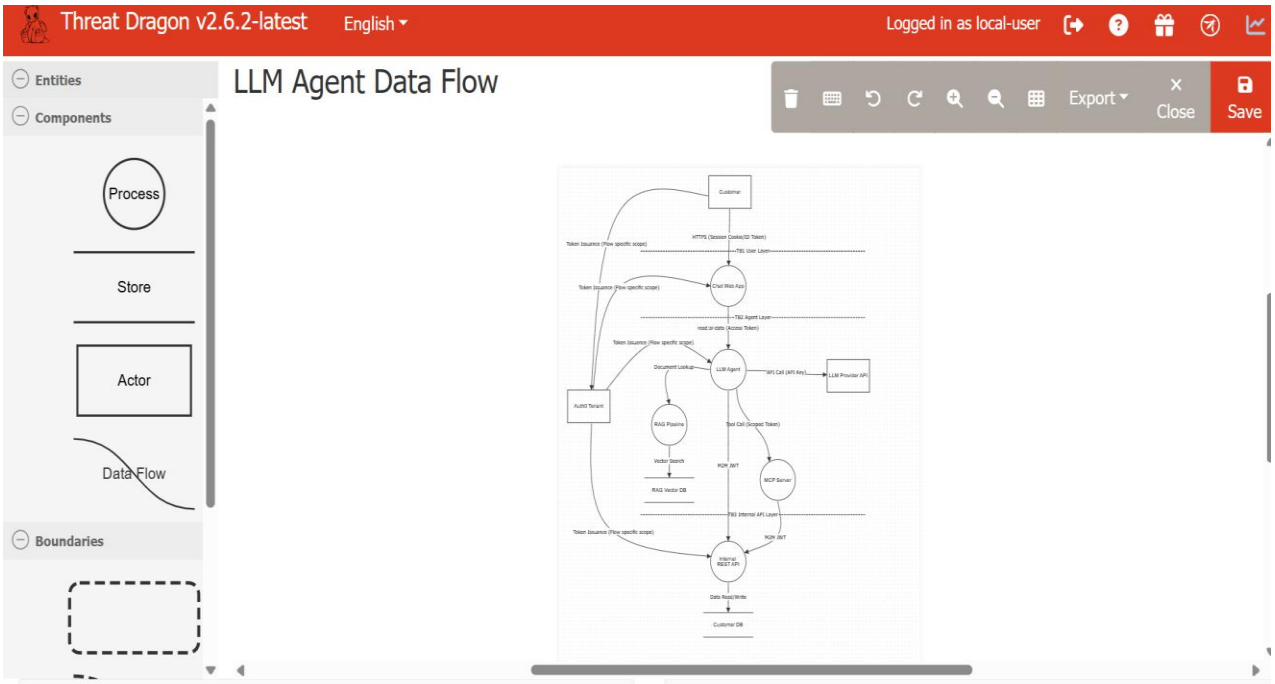
Flow	S (Spoofing)	T (Tampering)	R (Repudiation)	I (Info disclosure)	D (Denial of service)	E (Elevation)
User -> Chat App (login)	Credential stuffing / phished session	Token tampering in transit (mitigated TLS)	User denies action; no per-user audit logs	ID token leakage in logs	Login flood	Account takeover -> admin
Chat App -> Agent (user token)	Stolen/replayed access token	Prompt tampering in request	Agent actions not tied to `sub`	Token echoed in LLM context	Token-heavy requests	Agent accepts self-asserted role
Agent -> LLM provider (API key)	Stolen API key used by attacker	Response manipulation	No key-level audit	Key exfil via prompt injection	Unbounded consumption / quota burn	Key shared across envs
Agent -> RAG pipeline	Fake KB source	Chunk poisoning	Unknown chunk provenance	Over-broad retrieval of other tenants' data	Vector DB exhaustion	Retrieved text treated as instructions
Agent -> MCP server	Tool-call forgery	Tool args tampered	No tool-call log	Tool returns PII	Tool call loops	Agent calls admin tool without scope
F6 Agent A ->	Orchestrator impersonation	Message altered mid-hop	Sender can deny instruction	Context leakage between agents	Message flood	Privileged action by spoofed message

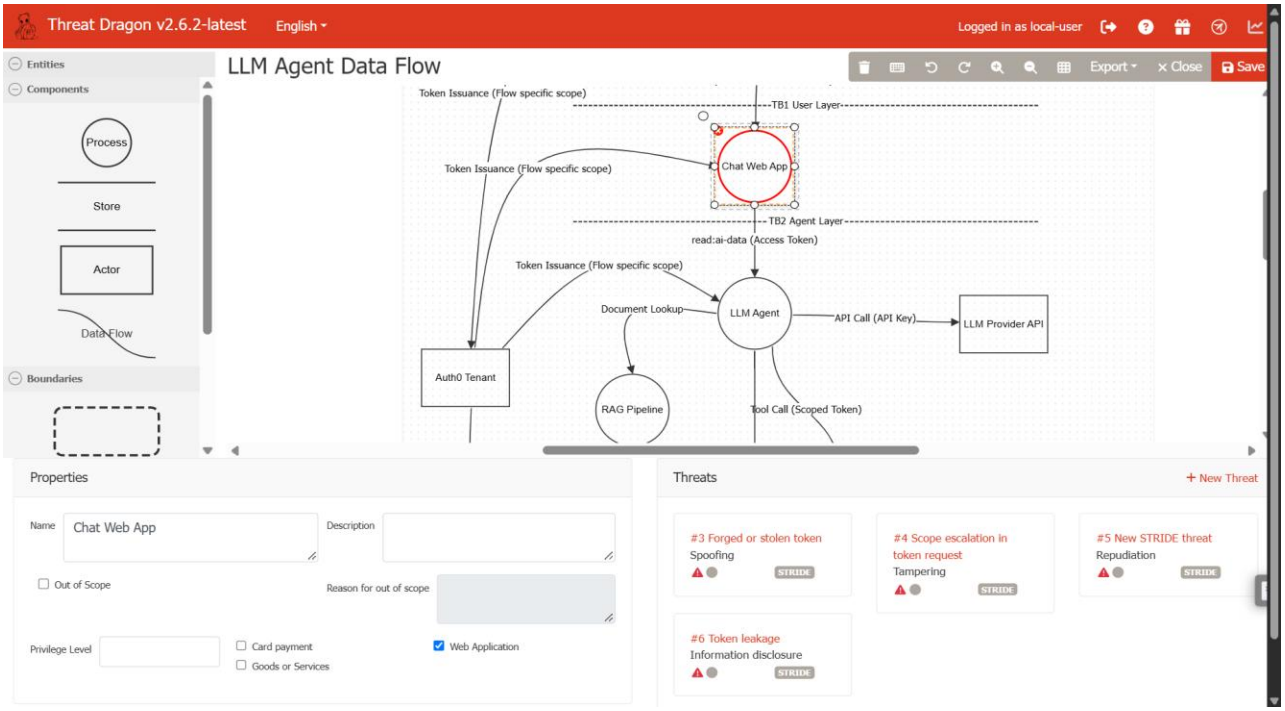
Agent B						
F7 M2M client -> Internal API	Client secret theft	JWT algorithm confusion	Missing `jti` / client audit	Long-lived tokens leaked	Token-endpoint abuse	Scope creep on M2M app
F8 Auth0 -> apps (token issue)	Rogue IdP / misconfigured callback	Claim tampering (needs RS256 verify)	Auth0 log retention too short	Verbose errors	Brute-force lockouts used as DoS	Overly broad scopes/audience

2.1 Data-flow diagram

This is the complete data-flow diagram (DFD) of the system built in **OWASP Threat Dragon** having three layers as **TB1**(User Layer), **TB2(**Agent Layer), **TB3(**Internal API Layer).



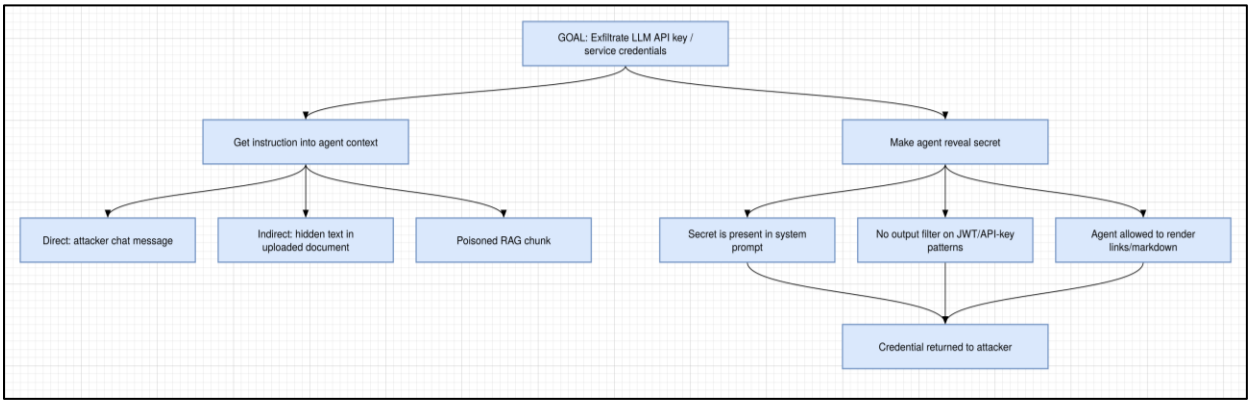




This image shows some of the STRIDE Threats for identity flow shown with red color in the diagram. **Auth0 Tenant → Chat Web App (Token Issuance).**

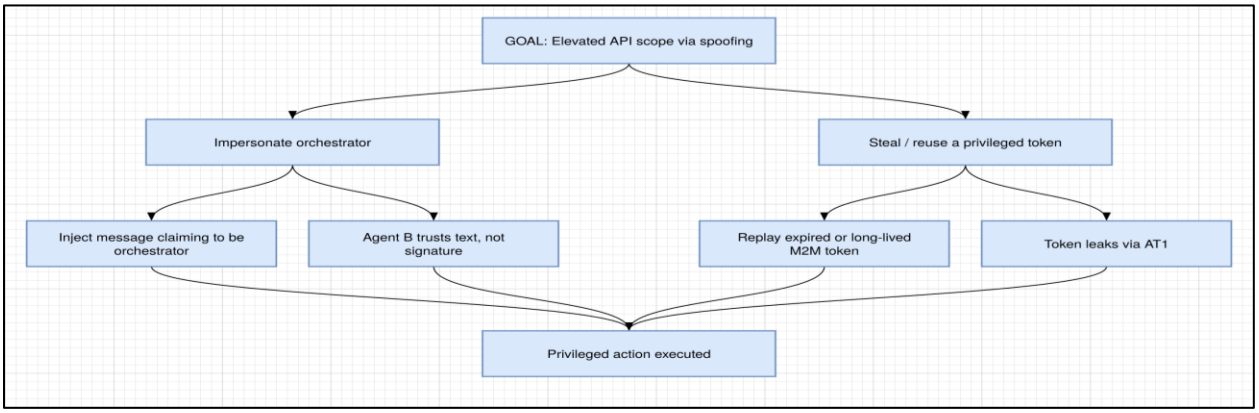
3. Attack Trees and The Scores of each Threat

3.1 LLM API key exfiltration via prompt injection



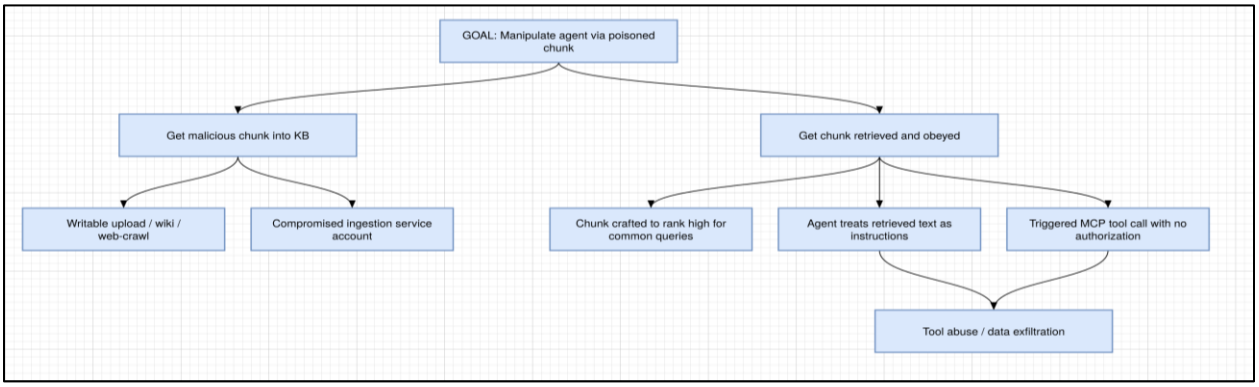
Risc Score = Likelihood x Impact = 4 x 4 = **16 (High)**

3.2 Agent identity spoofing to gain elevated API scope



Risc Score = Likelihood x Impact = 3 x 5 = **15 (High)**

3.3 RAG chunk poisoning to manipulate agent behavior



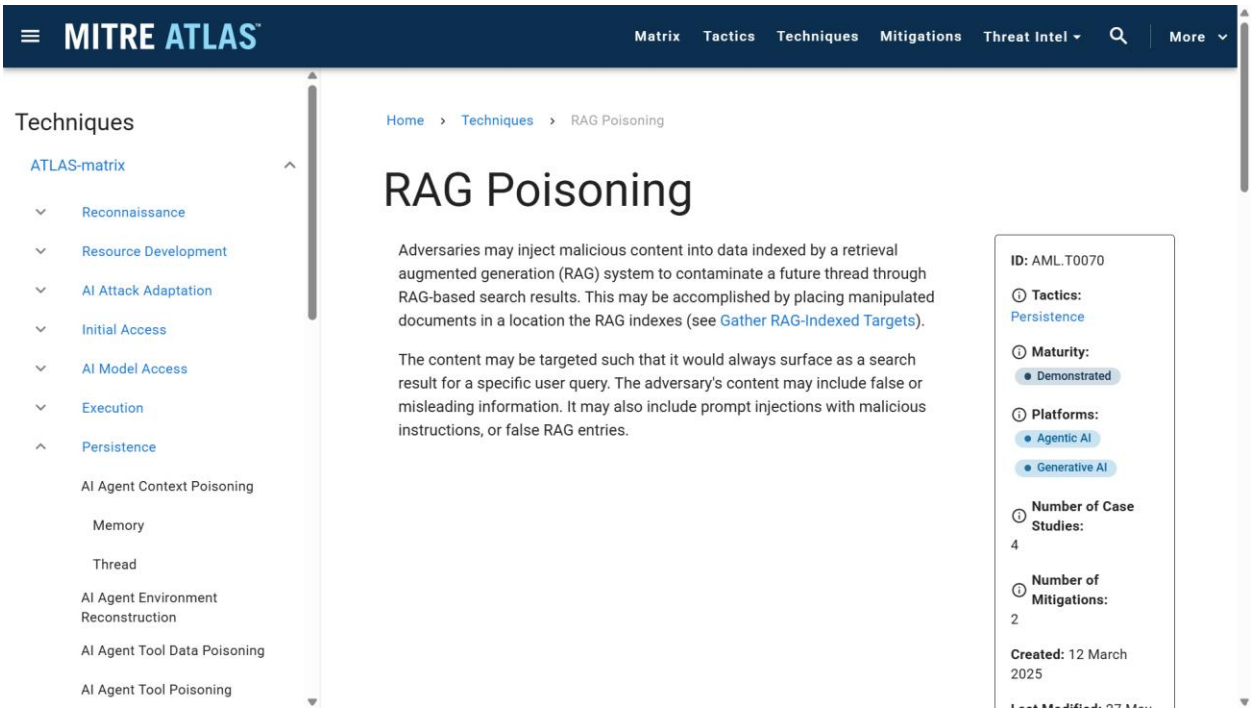
Risc Score = Likelihood x Impact = 4 x 4 = **16 (High)**

4. MITRE ATLAS Mapping

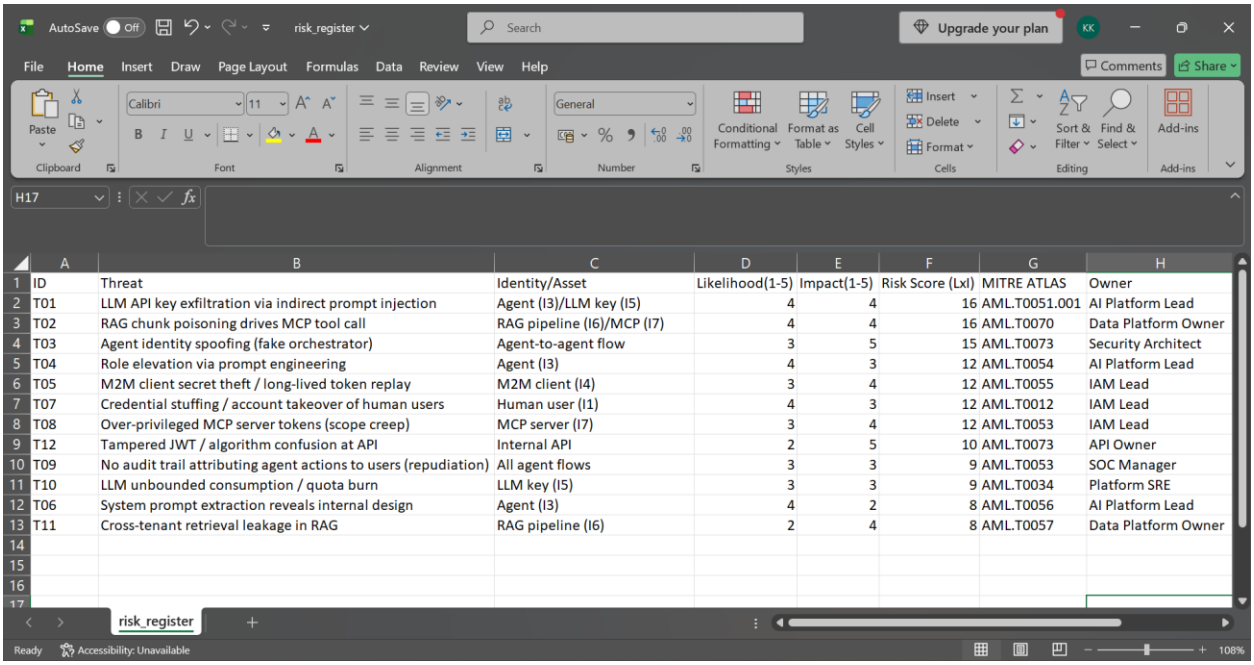
4.1 Mapping each Attack Tree to the Closest MITRE ATLAS Technique

Attack Tree Scenario	Closest ATLAS Technique	ATLAS ID
Key exfiltration via prompt injection	LLM Prompt Injection	AML.T0051
Agent identity spoofing	Impersonation	AML.T0073
RAG chunk poisoning	RAG Poisoning	AML.T0070

The above image provides the id of all the closest MITRE ATLAS Technique. And the image below shows the RAG Poisoning technique that we got on the mitre atlas organization.



4.2 Final Risk-Ranked Register



	A	B	C	D	E	F	G	H
1	ID	Threat	Identity/Asset	Likelihood(1-5)	Impact(1-5)	Risk Score (LxI)	MITRE ATLAS	Owner
2	T01	LLM API key exfiltration via indirect prompt injection	Agent (I3)/LLM key (I5)	4	4	16	AML.T0051.001	AI Platform Lead
3	T02	RAG chunk poisoning drives MCP tool call	RAG pipeline (I6)/MCP (I7)	4	4	16	AML.T0070	Data Platform Owner
4	T03	Agent identity spoofing (fake orchestrator)	Agent-to-agent flow	3	5	15	AML.T0073	Security Architect
5	T04	Role elevation via prompt engineering	Agent (I3)	4	3	12	AML.T0054	AI Platform Lead
6	T05	M2M client secret theft / long-lived token replay	M2M client (I4)	3	4	12	AML.T0055	IAM Lead
7	T07	Credential stuffing / account takeover of human users	Human user (I1)	4	3	12	AML.T0012	IAM Lead
8	T08	Over-privileged MCP server tokens (scope creep)	MCP server (I7)	3	4	12	AML.T0053	IAM Lead
9	T12	Tampered JWT / algorithm confusion at API	Internal API	2	5	10	AML.T0073	API Owner
10	T09	No audit trail attributing agent actions to users (repudiation)	All agent flows	3	3	9	AML.T0053	SOC Manager
11	T10	LLM unbounded consumption / quota burn	LLM key (I5)	3	3	9	AML.T0034	Platform SRE
12	T06	System prompt extraction reveals internal design	Agent (I3)	4	2	8	AML.T0056	AI Platform Lead
13	T11	Cross-tenant retrieval leakage in RAG	RAG pipeline (I6)	2	4	8	AML.T0057	Data Platform Owner
14								
15								
16								
17								

---------- **END OF PROJECT 1** ----------